

Password Security Policy

1. Introduction

A Password Security Policy is a set of rules and guidelines designed to protect user accounts, confidential information, and organizational systems from unauthorized access. Strong password practices help reduce the risk of cyberattacks, credential theft, and data breaches.

2. Objective

The objective of this policy is to establish secure password practices within an organization, promote strong authentication and protect sensitive information from unauthorized access.

3. Password Requirements

Length: Passwords should be at least 15 characters long wherever supported.

Uniqueness: Every account must have a unique password. Reusing passwords across different platforms should be avoided.

Complexity: Passphrases containing multiple unrelated words can be used to create strong, memorable passwords. Avoid predictable patterns and commonly used passwords.

Personal information: Do not use names, birthdays, phone numbers, or other easily guessed information.

Confidentiality: Passwords must never be shared with colleagues or unauthorized individuals.

Password changes: Change passwords immediately if they are suspected of being compromised. Routine forced changes are not necessary when there is no evidence of compromise and the password remains secure.

4. Password Managers

Employees should use an approved password manager to generate, store, and manage strong, unique passwords for different accounts.

A password manager reduces the need to memorize multiple passwords and helps prevent password reuse. Its master password must be strong, unique, and protected with multi-factor authentication wherever supported.

5. Multi-Factor Authentication

Multi-factor authentication adds another layer of security by requiring users to verify their identity using two or more different types of authentication factors.

Examples include:

- Something you know, such as a password.

- Something you have, such as an authenticator device or security key.
- Something you are, such as a fingerprint.

MFA should be enabled on email accounts, administrator accounts, cloud services, and other critical organizational systems. Phishing-resistant authentication, such as passkeys or security keys, should be preferred where available.

6. Password Storage and Protection

- Passwords must be stored securely using approved password-hashing methods rather than plaintext.
- Passwords must not be written on visible notes or stored in unprotected documents.
- Login systems should implement protections against repeated failed login attempts.
- Employees should avoid entering credentials on suspicious websites.
- Default passwords must be changed before systems are used in production.

7. Employee Responsibilities

Every employee is responsible for protecting their login credentials, using unique passwords, enabling MFA, and reporting suspicious login notifications or suspected account compromise to the IT or security team.

Employees must not approve unexpected MFA requests or share verification codes with anyone.

8. Incident Response

If an employee suspects that their password has been stolen or exposed, they should:

- Change the compromised password immediately using the official website or application.
- Report the incident to the IT or security team.
- Revoke suspicious sessions and review recent account activity.
- Change the same password on any other account where it was reused.
- Enable or verify MFA and follow the organization's recovery instructions.